Is penetration testing a suitable tool for a large-scale dynamic environment?

Abstract

Today, more than ever, businesses, institutions, organizations and enterprises need reliable security controls to counter dynamic threats, protect their perimeter-less environments, prevent malicious activity, and manage risk. Attackers have become more dangerous, precise and relentless and, in order to understand their scope, one of the most powerful and used methods is Penetration Testing (PT). Its capacity to discover security leaps and vulnerabilities has been undeniable during the last decades and it has played a critical role in many instances, however lately something has changed due to the exponential growth of heterogeneity in modern IT infrastructures and software. Although its usefulness, time constraints, the huge quantity of systems to be tested and the lack of human experts make PT lose its charm when it comes to risk assessment. Nevertheless, technological advancements have been made also on the defensive side (Blue Team) and this essay explains how researchers have tackled some of the challenges encountered when securing large-scale dynamic environments. The next sections will provide an holistic perspective of some of the current problems of pentests with a Purple Team point of view. Therefore there will be a critical analysis of the attacker side (Red Team) along with defensive strategies and solutions, concluding with in depth considerations on the integration in PT of the most discussed tool in the tech industry nowadays: artificial intelligence.

1 Introduction

Penetration testing (pentest) is an authorized, time-limited security assessment performed by experts with the aim of identifying and reporting eventual vulnerabilities in the targeted IT infrastructures, applications, networks and policies. This experiment is performed using the same tools, techniques and mindset that perpetrators would have (Red Teaming). Professionals then document findings and provide immediate and long-term remediation. PT is critical for vulnerability assessment and risk management. Through the years simulated security assessments became the key to achieve a robust security posture thanks to its ability to retrieve both qualitative and quantitative data [1]. Its relevance is due to its capacity to reveal overlooked features and highlight liability in a company's security frame, that, for example, could be whether the need to update the used tools and machines or a staff training session on security awareness. In a fast-pace environment such as the cyberworld, changes take place continuously. On the other hand, legacy manual penetration testing has proportionally started to become outdated in some instances, considering its lack of versatility to adapt to dynamic environments, especially the large-scale ones [8, 10]. It is easy to understand that the complexity of infrastructures is exponentially increasing and, trying to break through such systems, it's becoming proportionally harder and almost impossible in some cases. In the following sections, some of the main concerns about the adaptability of pentests are discussed along with considerations regarding security assessments in the current AI (artificial intelligence) era, given the latest technological advancements.

2 The new cyber threat landscape

As aforementioned the current era is characterized by the empowerment and diffusion of AI adoption. A really useful tool introduced in every aspect of the modern lifestyle and in every sector, spanning from medical fields to niche industries. All of these sectors have in common the use of cutting-edge and super complex technologies. However, at the same time, the implementation of these elements brings the same probability to be exploited and raises concerns about the risks AI poses to global cybersecurity. AI is not only useful to the industries that are developing new systems, for example, cyber security companies integrating this tool to their tech stack, instead it is also useful to attackers (Red Team). The latter uses LLMs (Large Language Models) in order to search for new exploits that come along with the implementation of newer technologies, in some cases even zero-day or one-day vulnerabilities [3, 18]. That's the reason why the modern cyber threat landscape has expanded and evolved. AI emerged as a new threat vector. PT must simulate its behaviour in order to understand the chain of thoughts of an eventual attacker when AI tools are deployed. However, to do this, there is the need of a versatile framework or a meticulous simulation that adapts to dynamic environments that compose modern infrastructures and systems. New challenges have been posed to experts in this field and researchers have highlighted the scarcity of human experts. Conventional approaches are limited by simplified action spaces, high computational costs and weak reasoning across the multi-stage process of the cyber kill chain [8, 10].

3 The heterogeneity of modern enterprise infrastructure systems

The limitations of penetration testing, listed in the previous section, get even worse when you consider what defenders must face within modern infrastructures, considering that they run huge heterogenous systems. The definition of heterogeneity from a cyber, or cyberphysical [19], perspective is the integration and interaction of different technological components, either hardware or software (e.g. IoT or Microservice Architecture), within a single system. The scale of its impact proportionally increases with the size and complexity of the enterprise environment, as larger systems are composed by several platforms, protocols, devices and a applications. The development of modern IT infrastructures introduces heterogeneity in terms of operating systems and software versions [10, 13]. For instance, there are many different hosting servers (e.g. Windows Server 2012/2016/2019/2022, Ubuntu 18.04/20.04/22.04, RHEL 7/8/9, etc.), clustered solutions, isolated VMs, complex technological stacks that integrate numerous services (Legacy monolith + Microservices Architecture) [17] and networks that have a DMZ perimeter. PT already has a lot of constraints (time, authorizations,

legal and ethical concerns) and lately the introduction of new technologies and numerous integrations has led to the impracticality of manual pentesting due to its inefficiency when facing large-scale environments. Experts face these limitations while testing increasingly complex systems, requiring the assessment of exponentially more elements. Moreover, they started addressing the issues that are making simulated security assessments less effective [8, 10]. Legacy penetration testing [7] is based on the cyber kill chain [14] and at the moment, even with the fastest human and tools, the paths to be covered just during the "reconnaissance" phase are huge and resource consuming [7]. It can be estimated an ($O(n^2)$) grade of complexity, given the explosion of integration points [17] (the number of interactions is estimated to grow quadratically with the number of services). Considering this, in the next paragraphs some of the arose concerns are illustrated more in detail.

3.1 Related problems

Considering the new threat landscape (see sec. 2) and the infrastructures' heterogeneity (see sec. 3) that is affecting dramatically penetration testing, in the next sections it will be illustrated how LLMs have been integrated in penetration testing, but first, two of the main issues addressed by experts will be discussed in depth: **fragmentation** of the attack surface (4) and the **obsolescence** of the legacy vulnerability scoring system (5).

4 Fragmentation of the attack surface

In the context of large-scale enterprises, the **fragmentation** of the attack surface can be defined as the exponential growth of the scope of an eventual penetration test [13, 19]. What that means is that when a simulated security assessment is commissioned, if the company subject of the test is running multi layered, integrated, interlinked applications, protocols and software, most likely in cloud, chances are that the team of experts tasked to test the security of it can't manage at all at defining the scope of the assessment. For instance, consider an application to be tested against an SQL Injection, but that application actually communicates with another service for API calls that sends data to another service that manages queries and so on and so forth until, eventually, it reaches a database and gives back an output. From this example, the concept introduced in the section 3 can be understood. It shows how a Microservice Architecture makes the attack surface area to be covered exponentially bigger [17] ($O(n^2)$ grade of complexity). Just to give an even better insight on what fragmentation could be, another example can be the collateral effect caused by the dynamism of spiralling cloud based infrastructures. Imagine assessing a vulnerability of a container in a cloud environment managed with Kubernetes, reporting the found vulnerability, remediation etc. and then suddenly that same container gets deleted automatically by Kubernetes that uploads another container with the same functionality but patched. This is a clear example of why the conventional approach to PT is getting outdated: the tester doesn't even have the time to submit the report. The framework with which testers write reports implies that the client needs to be able to reproduce the steps made to exploit the vulnerability, but this last example shows how even experts actually don't know anymore what to test because of the dynamism of the modern infrastructures. Having to be this fast is humanly impossible and one of the reason why experts have begun shifting towards automated solutions in the last decade. Moreover, they started off with automation scripts, then they started introducing Machine Learning (ML), Deep Learning (DL), Reinforced Learning (RL) but these approaches remain limited by rigid action spaces and high computational costs. The latest introduction was the automation through AI because most of the security teams are finally realizing that "the best defence is attack". They started Red Teaming against their own infrastructure, performing automated PTs on a regular basis and therefore adopting a Purple Team approach, hunting continuously for exploits and then patching, updating or deleting components. A deep dive into "AI pentesting" can be found in the section 6, along with actual data and considerations. Going back to the problems related to the new threats and infrastructures, in the next section it will be explained in detail why also the legacy scoring system has become unreliable and why it fails to the describe the actual severity of the found vulnerabilities in the latest cyber architectures.

5 Vulnerability scoring system obsolescence

The most utilized vulnerability scoring system is the Common Vulnerability Scoring System (CVSS). It is an open industry standard designed to assess the severity of vulnerabilities found in systems. It is managed by the non-profit FIRST organization (Forum of Incident Response and Security Teams) and it provides numerical representation of the potential impact a vulnerability could have, helping organization prioritize them on a scale. The National Vulnerability Database (NVD), managed by the National Institute of Standards and Technology (NIST), utilizes CVSS to assign a score to confirmed vulnerabilities. This information is publicly available [2, 4, 11, 12]. The core issue with this vulnerability metric, that many agree on, is that CVSS isn't able to describe the vulnerabilities in modern complex systems. In an article from 2021, Spring et al. (CERT Coordination Center (CERT/CC) researchers) stated that, at that time, the Common Vulnerability Scoring System algorithm (v3.0) "is not justified, either formally or empirically. According to the specification, using CVSS directly as a risk score is a mistake. [..] We argue that the current CVSS version is still inadequate for both its intended purpose and as a proxy for risk to a vulnerable system" [16]. Furthermore, JFrog, a security tools vendor, in 2022 performed an analysis of the top 50 Common Vulnerabilities and Exposures (CVEs) to assess the real-world effects of these on the open-source world [6]. What they pointed out, instead, was the discrepancy between the CVSS scoring provided by the National Vulnerability Database (NVD) and their own severity assessment [2]: (1) The NVD provided scoring was overestimating the actual vulnerability 64% of the time; (2) Threats marked as **significant** were actually of marginal impact in a real-word scenario due to the complexity of the exploitation and (3) 10 of the most relevant vulnerabilities impacting enterprises had low CVSS severity ratings delaying the remediation and increasing the risk of exploitation overtime. It could be argued that it still a valid scoring system, even approved and used by NIST, but from a penetration testing point of view, considering the current cyber threat landscape (see sec. 2) and the modern infrastructures (see sec. 3), the CVSS doesn't

provide the needed information. Moreover, it doesn't really consider the context, the exploitation complexity and the scoring is static because it does not consider the developments in exploits or information [6, 16]. This leads to the misinterpretation and misclassification of threats. Nevertheless, CVSS v4.0 includes significant improvements. The aforementioned issues were related to the version 3.0 and now the version 4.0 is available from 2025. It is being developed by FIRST [5], it now allows product developers to be more specific to provide more context on the vulnerability (urgency and specific information) and it also incorporates more metrics that help describing environmental conditions and exploit code maturity [2, 5]. The Executive Director of FIRST, Chris Gibson, argued that CVSS is not the perfect scoring system or a complete solution. It must be considered such: it does not account for contextual factors like specific environments or operational impact and security teams should use it alongside other risk assessment tools [2, 5]. Organizations are recommended to use CVSS considering the environmental factors and integrate it in a broader risk management framework including threat intelligence while critically defining their assets. However, the key recommendation is the dynamic prioritization that aligns with what was the conclusion in the previous section: regular testing and assessments to continuously update reports as new information is available, including exploit developments and patch releases. So essentially Purple Teaming is being advised [2, 5]. To conclude it can be said that the standard vulnerability scoring system is getting obsolete in the penetration testing due to the fragmentation of newer infrastructures and the need of continuos updates in reports and threat prioritization. Steps towards a solution to this problem have been made and this involves the automation of the simulated security assessment process through LLMs [3, 8–10]. The next section provides an exhaustive illustration of some of the latest results of research and development made for this integration.

6 Penetration testing with AI and considerations

Today's security and assessments requirements and needs are not being met with conventional penetration testing approaches [7, 15]. The new environments to be tested are huge, fast, unpredictable, dynamic and therefore, manual PT is not the way to go anymore. Experts and professionals understood this issue and started leveraging AI to automate and scale the steps that compose the cyber kill chain [14] in order to tackle the challenges that modern architectures pose from an attack simulation and risk management perspective. The main goal they had in mind was being able to perform pentests regularly without being constrained by time and resource limits, so rather than having a single human expert sequentially executing reconnaissance, exploitation and post exploitation, they wanted to create something able to perform simultaneously a chain of actions on different hosts. Duc Luong et al. (2025) stated that "as networks grow in scale and complexity, the gap between the appearance of new vulnerabilities and the ability of security professionals to detect and remediate them is widening. This growing imbalance underscores the urgent necessity for automated and intelligent penetration testing solutions. Early attempts to narrow this gap focused on fully deterministic or heuristic automation." Researchers started experimenting with what they had at the time, so they started first implementing scripts to automate some time consuming steps (e.g. reconnaissance, weaponization or delivery), referring to frameworks such as MITRE ATT&CK [15] (e.g. Metasploit based scripting [10] or T1046 Network Service Scanning, T1595 Active Scanning, and related information gathering), that assert a playbook of known tactics and techniques to specific executable actions. Later on, Machine Learning (ML) became more popular, leading to the innovation of PT through this mechanism following with Deep Learning (DL) and lastly Reinforcement Learning (RL) [8, 10]. Despite looking promising at first sight, all of these solutions encountered problems regarding the lack of versatility, rigid setups and resource inefficiency. "These limitations illustrate that purely Deep Learning (DL) or RL-based automation is insufficient for the inherently multiphase and dynamic nature of penetration testing. To overcome this, recent works have turned toward AI agent-based paradigms, in which multiple specialized agents collaborate to emulate the workflow of human red teams. [10]". The LLM approach assigns a role and task to a different agent. An AI agent is equipped with a "neural network" making it able to think and take decisions based on the data and instructions upon it was trained. In this case each of the AI agent is specialized in a distinct phase of the cyber kill chain [7, 14, 15]. Therefore, for example, there is an agent that performs the *reconnaissance* phase focusing on host and service discovery, another one that analyses the found vulnerabilities matching findings with CVE and CWE data with which it was trained, and an agent for exploitation processes [10]. There are many more fine-tuned agents that can be deployed based on the needs of the tester or the target architecture, but mainly the AI agent approach enhances the kill chain by parallelizing phases executing actions on multiple hosts simultaneously, using chain techniques [15] and rerunning dynamically actions based on the changes in the network or infrastructure. All of this in order to reduce the errors and improve the efficiency [10]. During the research for this essay, several papers have been found to be using MITRE ATT&CK based agentic penetration testing [8–10] and a lot of interesting data was available, but for the sake of the scope of this essay, Lin et al.'s ARTEMIS study, published in December 2025, provides the first comprehensive evaluation of AI agents comparison with human cybersecurity professionals in a live enterprise environment [9]. ARTEMIS is a cutting-edge multi-agent framework that has been deployed composed by three main components: (1) a supervisor that orchestrates the actions of the sub-agents, (2) a swarm of fine-tuned sub-agents with dynamically generated expert system prompts, (3) and a triaging module for vulnerability verification [9]. In the documented experiment it has been deployed on a large research university's Computer Science network (12 subnets, approximately 8,000 hosts) and the innovation this framework brings directly addresses the fragmentation issue presented in the section 4: when a potential exploit target is identified during reconnaissance the supervisor spawns a dedicated sub-agent to test that target in parallel, sometimes resulting in multiple simultaneous exploitation threads. At peak, ARTEMIS maintained 8 active sub-agents working in tandem, achieving systematic enumeration and parallel exploitation that human testers, constrained to sequential analysis, cannot match [9]. The aim of this framework is to

employ dynamic prompt generation, versatility, autonomous decision making based on the discovered vulnerabilities, and includes automatic vulnerability triaging to reduce false positives and verify submission quality before reporting. This also implies dynamically updating reports and therefore addressing the concerns raised in the scoring system (see sec. 5).

6.1 Results and final considerations

The results demonstrate AI's potential but also remarks current limitations. ARTEMIS found 9 valid vulnerabilities with an 82% correct submission rate, ranking it second overall among 10 human professionals and surpassing 9 of them in terms of vulnerability complexity and business impact [9]. Critically, ARTEMIS achieved this at a cost of $18.21 per hour compared to $60 per hour for professional penetration testers: a 69.65% cost reduction [9]. In terms of methodology, both ARTEMIS and humans followed similar kill-chain steps (scan, target, probe, exploit, repeat), but ARTEMIS's ability to use several threads provided significant advantages: while human participants worked sequentially on individual hosts, ARTEMIS simultaneously exploited different targets in parallel [9]. Nevertheless, critical gaps remain. ARTEMIS had difficulty with GUI-based interactions: while 80% of human participants successfully exploited a remote code execution vulnerability on the TinyPilot web interface, ARTEMIS failed to interact with the browser-based system, instead finding lower-severity misconfigurations [9]. Moreover, ARTEMIS submitted more **false positives** than human participants. This suggested that, although AI excels at systematic enumeration and parallel exploitation, there is room for improvement on the contextual judgment and visual reasoning necessary for complex scenarios. These findings indicate that the optimal security posture is not "AI-replaces-humans" but rather "AI-augmented humans". This way, AI agents speed up reconnaissance and systematic scanning while human experts handle exceptions, interact with GUIs, and make strategic decisions.

7 Conclusions

Summarizing, it can be said that PT is evolving along with the technological advancements [3, 8–10] and is adapting to the needs of current cyber architectures (networks, infrastructures, etc.). The purpose of the current study was to argue whether or not, penetration testing is a valid tool when it comes to large-scale dynamic environments. The answer is nuanced and depends on the context. The ARTEMIS study [9] provide evidence on how the automation of pentesting has evolved so far, moving from Reinforcement Learning [8], addressing the issues outlined in the sections 4 and 5. This evolution brings with it a lot of room for improvement (AI's visual reasoning capabilities and reducing false positives), but still, it shows that researchers are adapting, tackling challenges posed by the adoption of new technologies and that the best security posture is neither "AI-replaces-humans" nor manual pentesting alone, but rather "AI-augmented pentesting". Some might argue that it is still too early to use AI in cybersecurity, considering the risk of errors and the severity of the role it would cover in enterprise environments. However, to conclude, it can be said that arguably cybersecurity is a science and therefore, a statement can be made only after experimenting hypothesises, in this case testing new AI tools and strategies in PT over newer architectures, searching for a solution in a continuously expanding environment.

A Generative AI Usage Disclosure

Perplexity (Pro Version) by Perplexity AI, Inc. (https://www.perplexity.ai) was used for tone and readability feedback, grammar and spelling checks, and academic literature discovery (supplemented by Scopus, OneSearch, ACM Digital Library, and IEEE Xplore).

References

[1] Florian Arnold, Wolter Pieters, and Mariëlle Stoelinga. 2013. Quantitative penetration testing with item response theory. In *2013 9th International Conference on Information Assurance and Security (IAS)*. 49–54. doi:10.1109/ISIAS.2013.6947732

[2] Elementrica. 2025. *Why CVSS Scores Often Fail to Reflect Real-World Risks: Beyond the Numbers.* https://elementrica.com/news/why-cvss-scores-often-fail-to-reflect-real-world-risksbeyond-the-numbers-cvss-score-fails-to-reflect-real-world-risks/ Online; accessed January 7, 2026.

[3] Richard Fang, Rohan Bindu, Akul Gupta, and Daniel Kang. 2024. LLM Agents can Autonomously Exploit One-day Vulnerabilities. arXiv:2404.08144 [cs.CR] https://arxiv.org/abs/2404.08144

[4] Inc. FIRST.Org. 2025. *Common Vulnerability Scoring System (CVSS).* https://www.first.org/cvss/ Accessed: 2026-01-05.

[5] Chris Gibson. 2025. *Why No Organization Can Face Cybersecurity Alone.* https://cybernews.com/security/chris-gibson-first-why-no-organization-can-face-cybersecurity-alone/ Interview with Chris Gibson, CEO/Executive Director of FIRST. Accessed: 2026-01-09.

[6] JFrog Security Research Team. 2023. *2023 JFrog Security Research Report: Critical Vulnerability Analysis of Top 50 CVEs.* https://jfrog.com/whitepaper/in-depth-analysis-of-open-source-security-vulnerabilities-most-impactful-to-devops-and-devsecops-teams/ Accessed: 2026-01-05.

[7] Gus Khawaja. 2021. *Kali Linux Penetration Testing Bible* (1st edition ed.). John Wiley & Sons, Incorporated, Newark.

[8] Qianyu Li, Ruipeng Wang, Dong Li, Fan Shi, Min Zhang, Anupam Chattopadhyay, Yi Shen, and Yang Li. 2024. DynPen: Automated Penetration Testing in Dynamic Network Scenarios Using Deep Reinforcement Learning. *Trans. Info. For. Sec.* 19 (Jan. 2024), 8966–8981. doi:10.1109/TIFS.2024.3461950

[9] Justin W. Lin, Eliot Krzysztof Jones, Donovan Julian Jasper, Ethan Jun shen Ho, Anna Wu, Arnold Tianyi Yang, Neil Perry, Andy Zou, Matt Fredrikson, J. Zico Kolter, Percy Liang, Dan Boneh, and Daniel E. Ho. 2025. Comparing AI Agents to Cybersecurity Professionals in Real-World Penetration Testing. arXiv:2512.09882 [cs.AI] https://arxiv.org/abs/2512.09882

[10] Phung Duc Luong, Le Tran Gia Bao, Nguyen Vu Khai Tam, Dong Huu Nguyen Khoa, Nguyen Huu Quyen, Van-Hau Pham, and Phan The Duy. 2025. xOffense: An AI-driven autonomous penetration testing framework with offensive knowledge-enhanced LLMs and multi agent systems. (2025).

[11] National Institute of Standards and Technology. 2022. *Vulnerability Metrics: CVSS in the National Vulnerability Database.* https://nvd.nist.gov/vuln-metrics/cvss Accessed: 2026-01-05.

[12] National Institute of Standards and Technology. 2025. *National Vulnerability Database (NVD).* https://nvd.nist.gov/ Accessed: 2026-01-05.

[13] Muhammad Noaman, Muhammad Sohail Khan, Muhammad Faisal Abrar, Sikandar Ali, Atif Alvi, Muhammad Asif Saleem, and Xu Zhang. 2022. Challenges in Integration of Heterogeneous Internet of Things. *Scientific programming* 2022 (2022), 1–14.

[14] Racheal Popoola and LinkedIn Learning. 2024. Introduction to the Cyber Kill Chain. https://www.linkedin.com/learning/introduction-to-the-cyber-kill-chain?u=83351972&auth=true

[15] Drinor Selmanaj. 2024. Adversary emulation with MITRE ATT&CK : bridging the gap between the red and blue teams.

[16] Jonathan Spring, Eric Hatleback, Allen Householder, Art Manion, and Deana Shick. 2021. Time to Change the CVSS? *IEEE Security & Privacy* 19, 2 (2021), 74–78. doi:10.1109/MSEC.2020.3044475

[17] T. Vukadinović. 2025. On the Vulnerability of Modern Microservice Frameworks. In *Proceedings of the Workshop on Security of Microservices*, Vol. 3971. CEUR-WS, paper14. https://ceur-ws.org/Vol-3971/paper14.pdf

[18] Rhiannon Williams. 2025. The Download: using AI to discover "zero day" vulnerabilities, and Apple's ICE app removal. *MIT Technology Review.com* (2025).

[19] Hyunguk Yoo and Taeshik Shon. 2016. Challenges and research directions for heterogeneous cyber–physical system based on IEC 61850: Vulnerabilities, security requirements, and security architecture. *Future Generation Computer Systems* 61 (2016), 128–136. doi:10.1016/j.future.2015.09.026